Perimeter Health Audit: candykittens.co.uk

Generated on October 03, 2026 at 16:14 UTC | Confidential Client Report

C
OVERALL GRADE

Security Hygiene Score: 65 / 100
Monitored Apex: candykittens.co.uk
Subdomains Scanned: 9 endpoints
Identified Vulnerabilities: 10 items

Retainer Status: Active Protection
Next Audit: 1st of Next Month
Support: ops@eastsideco.com
Web: https://eastsideco.com

Perimeter Findings & Remediation Items

MEDIUM

1. DMARC Policy in Inactive Monitoring Mode (p=none) — [Email Authentication]

Target: `_dmarc.candykittens.co.uk`
Details: The DMARC policy is set to `p=none`. Spoofed emails from attackers are still delivered to recipient inboxes without rejection or quarantine.
Evidence: `v=DMARC1; p=none; rua=mailto:dmarc@candykittens.co.uk; ruf=mailto:dmarc@candykittens.co.uk; sp=none; pct=100`
Remediation: Upgrade policy from `p=none` to `p=quarantine` or `p=reject` after reviewing authentication reports.

LOW

2. Missing BIMI Brand Indicator (RFC 8617) — [Email Authentication]

Target: `default._bimi.candykittens.co.uk`
Details: No BIMI record discovered at `default._bimi.candykittens.co.uk`. Implementing BIMI authenticates brand logos in supporting inboxes (Gmail, Apple Mail, Yahoo) and prevents visual brand spoofing.
Evidence: `No BIMI TXT record located.`
Remediation: Configure a DNS TXT record at `default._bimi.candykittens.co.uk` with `v=BIMI1; l=https://candykittens.co.uk/logo.svg;`.

LOW

3. Missing MTA-STS Transport Security (RFC 8461) — [Email Authentication]

Target: `_mta-sts.candykittens.co.uk`
Details: Domain candykittens.co.uk has no MTA-STS DNS record. Inbound emails remain vulnerable to SMTP TLS downgrade attacks and eavesdropping.
Evidence: `No MTA-STS record located.`
Remediation: Publish `_mta-sts.candykittens.co.uk` TXT record and establish mta-sts.txt policy endpoint.

INFO

4. Missing SMTP TLS Reporting (TLS-RPT RFC 8460) — [Email Authentication]

Target: `_smtp._tls.candykittens.co.uk`
Details: No TLS-RPT record found for candykittens.co.uk. Diagnostic telemetry on MTA transport security is unavailable.
Evidence: `No TLS-RPT record located.`
Remediation: Publish `_smtp._tls.candykittens.co.uk` TXT record with `v=TLSRPTv1; rua=mailto:...`.

LOW

5. Missing DNS CAA Policy (RFC 8659) — [Transport Security]

Target: `candykittens.co.uk`
Details: Domain candykittens.co.uk has no DNS CAA policy configured. Any globally trusted CA can issue certificates for this domain without restriction.
Evidence: `No CAA records found in DNS zone (The DNS response does not contain an answer to the question: candykittens.co.uk. IN CAA).`
Remediation: Publish a DNS CAA record for `candykittens.co.uk` restricting issuance to approved Certificate Authorities.

INFO

6. HSTS Header Incomplete (Subdomains or Preload) — [Transport Security]

Target: `https://candykittens.co.uk`
Details: HSTS header is active but does not declare `includeSubDomains` or `preload`. Subdomains may remain susceptible to SSL stripping.
Evidence: `Current HSTS: max-age=7889238`
Remediation: Strengthen HSTS header to `Strict-Transport-Security: max-age=63072000; includeSubDomains; preload`.

LOW

7. Missing Referrer-Policy Header — [Application Security]

Target: `https://candykittens.co.uk`
Details: No Referrer-Policy header is defined. Browsers may leak confidential URLs and query parameters in the Referer header to external destinations.
Evidence: `Header 'Referrer-Policy' not present.`
Remediation: Set `Referrer-Policy: strict-origin-when-cross-origin`.

INFO

8. Missing Permissions-Policy Header — [Application Security]

Target: `https://candykittens.co.uk`
Details: Permissions-Policy is missing. Modern web applications should explicitly restrict unnecessary browser features (camera, microphone, geolocation, payment).
Evidence: `Header 'Permissions-Policy' not present.`
Remediation: Configure `Permissions-Policy: camera=(), microphone=(), geolocation=()`.

INFO

9. Missing Cross-Origin-Opener-Policy (COOP) — [Application Security]

Target: `https://candykittens.co.uk`
Details: COOP header is not set. Isolating top-level browsing contexts prevents cross-origin Spectre and XS-Leak interactions.
Evidence: `Header 'Cross-Origin-Opener-Policy' not present.`
Remediation: Configure `Cross-Origin-Opener-Policy: same-origin` or `same-origin-allow-popups`.

LOW

10. Missing RFC 9116 Security Disclosure (security.txt) — [Application Security]

Target: `https://candykittens.co.uk/.well-known/security.txt`
Details: Domain candykittens.co.uk does not publish a standardized vulnerability disclosure policy at `/.well-known/security.txt` per IETF RFC 9116. Ethical security researchers and bug bounty reporters lack a designated, confidential channel to report zero-day vulnerabilities.
Evidence: `No valid security.txt discovered with Contact: directive.`
Remediation: Deploy a `security.txt` file at `https://candykittens.co.uk/.well-known/security.txt` declaring `Contact: mailto:security@candykittens.co.uk` and a valid `Expires:` date.